DPDP COMPASS

PROJECT REPORT · SEPTEMBER 2026

# India's privacy law, *decoded.*

A retrieval-augmented, multi-agent assistant for the Digital Personal Data Protection Act, 2023 and DPDP Rules, 2025 — for citizens who want to know their rights and businesses that need to comply.

| 71 | 11 | 7 | ~1 s |
|---|---|---|---|
| legal passages indexed | DPDP obligations audited | safety checks per answer | to first streamed words |

FastAPI · LangGraph · React · Groq

Educational guidance — not legal advice

01 · OVERVIEW

# What DPDP Compass does

**Snapshot of 30 September 2026.** The audit engine was rebuilt on 10 October 2026: the system now uses 83 clause chunks, a 14-obligation checklist and six guardrail checks. For the current design and measured results see `project/docs/DOCUMENTATION.md` and the paper in `project/docs/paper`.

DPDP Compass answers questions and audits privacy policies using only the text of the DPDP Act. Every answer cites the exact section or sub-clause it relies on — for example **§ 8(6)**.

**For citizens**

- Ask about data rights in English, Hindi or Marathi
- See what an app's privacy policy really says
- Get a trust score and the gaps that affect you

**For businesses**

- Audit a policy against 11 DPDP obligations
- Law and policy quoted side by side per finding
- Generate a compliant draft; export PDF / Word / MD

**Core principle — no citation, no claim.** The AI model only writes from passages of the law retrieved for the question. If the Act doesn't answer it, the assistant says so rather than guessing.

02 · ARCHITECTURE

# System architecture

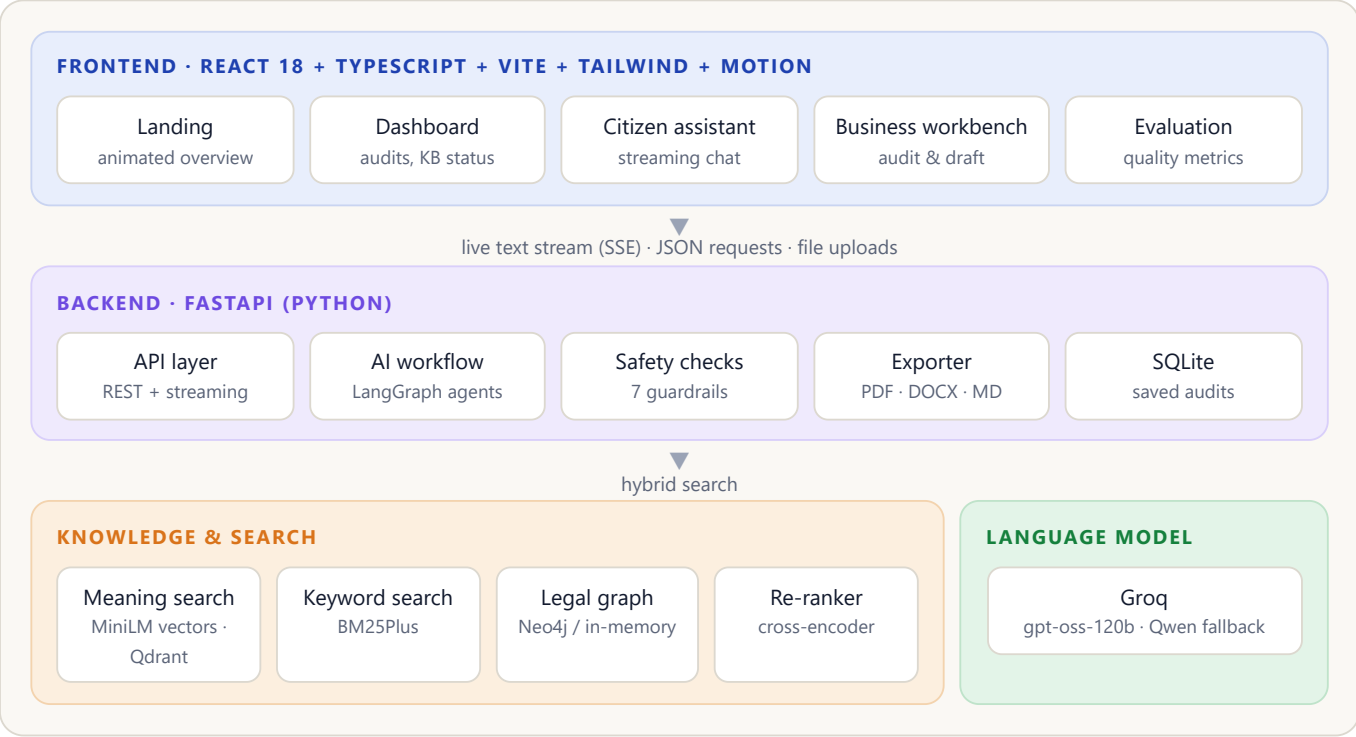



*Figure 1 — Layered architecture. Qdrant and Neo4j are used when running; otherwise in-memory fallbacks keep the system working.*

03 · KNOWLEDGE BASE

# What the system knows

| Source | Contents | How it is prepared |
|---|---|---|
| **DPDP Act, 2023**<br>Official Gazette text | 71 legal passages | Split at section and sub-clause boundaries — nothing truncated — so each passage keeps its exact citation, e.g. § 6(4) |
| **DPDP Rules, 2025** | Referenced | Deeper rule-level ingestion planned |
| **Reference privacy policies** | 69 passages from 10 apps | Zomato, Swiggy, Paytm, Flipkart, Zerodha, CRED, Razorpay, Meesho, Zepto, Blinkit — answers "what does this app do with my data?" |
| **Legal knowledge graph** | Subject → duty → object | e.g. *Data Fiduciary → must notify → Board*; surfaces related clauses keyword search misses |
| **User uploads** | PDF, DOCX, TXT, MD (≤ 10 MB) or URL | Parsed and chunked; URLs pass an SSRF security check first |

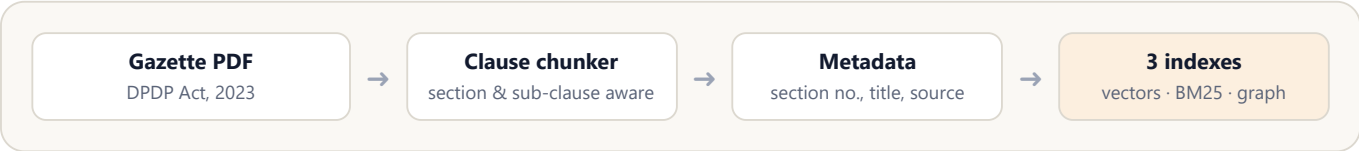



*Figure 2 — Ingestion pipeline for the law.*

## Inputs accepted

| Input | Where | Example |
|---|---|---|
| A question | Citizen assistant | "Can Zomato sell my phone number?" |
| An app name | Citizen assistant | "Zerodha" |
| Privacy-policy file | Citizen / Business | `company_policy.pdf` |
| Pasted policy text | Business → Audit | Full text of a privacy policy |
| Company details form | Business → Create | Name, sector, data collected, purposes… |

04 · WORKFLOW

# How a request is processed

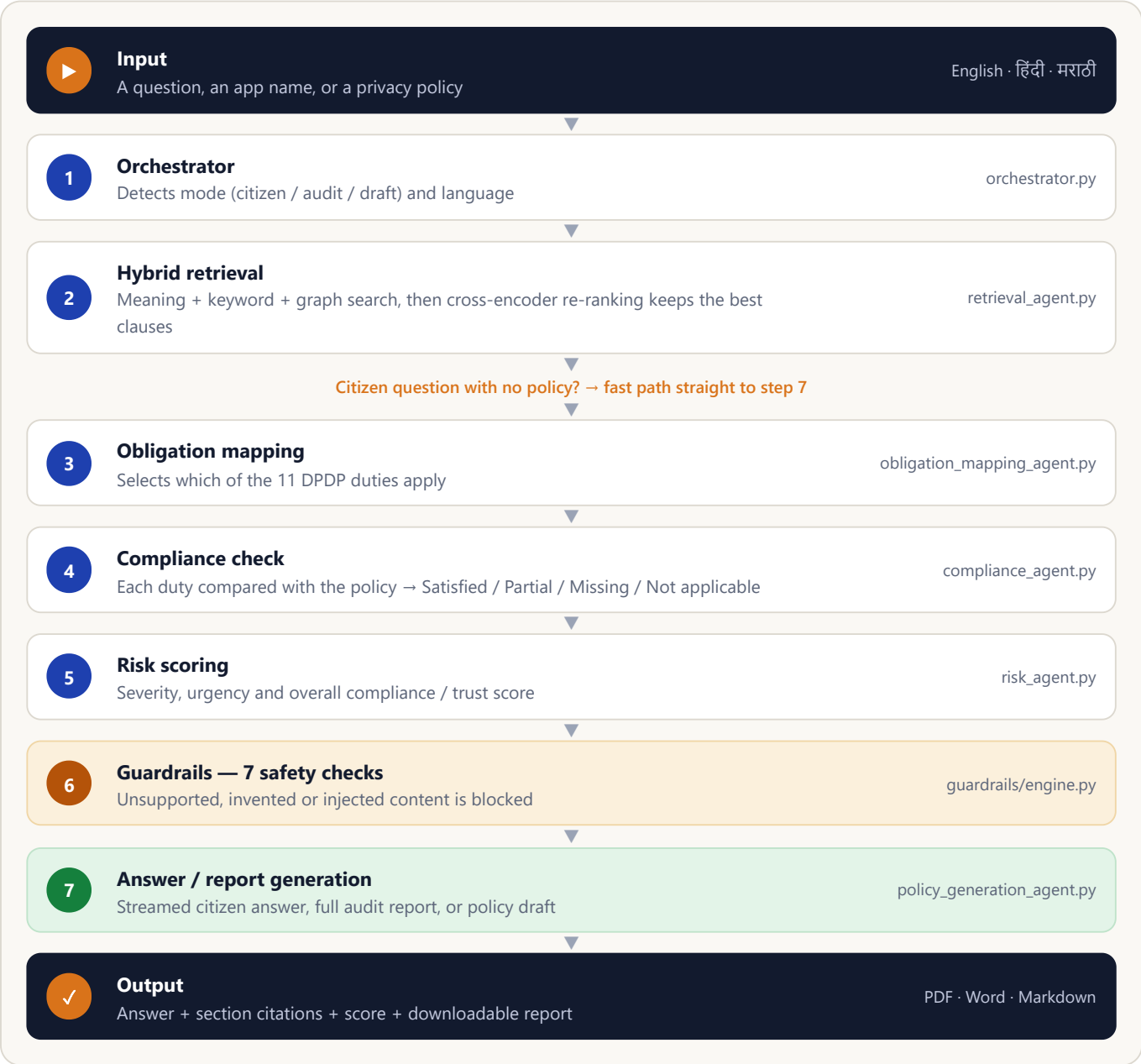



*Figure 3 — LangGraph agent pipeline (app/graph/workflow.py).*

### Streaming — how an answer appears live

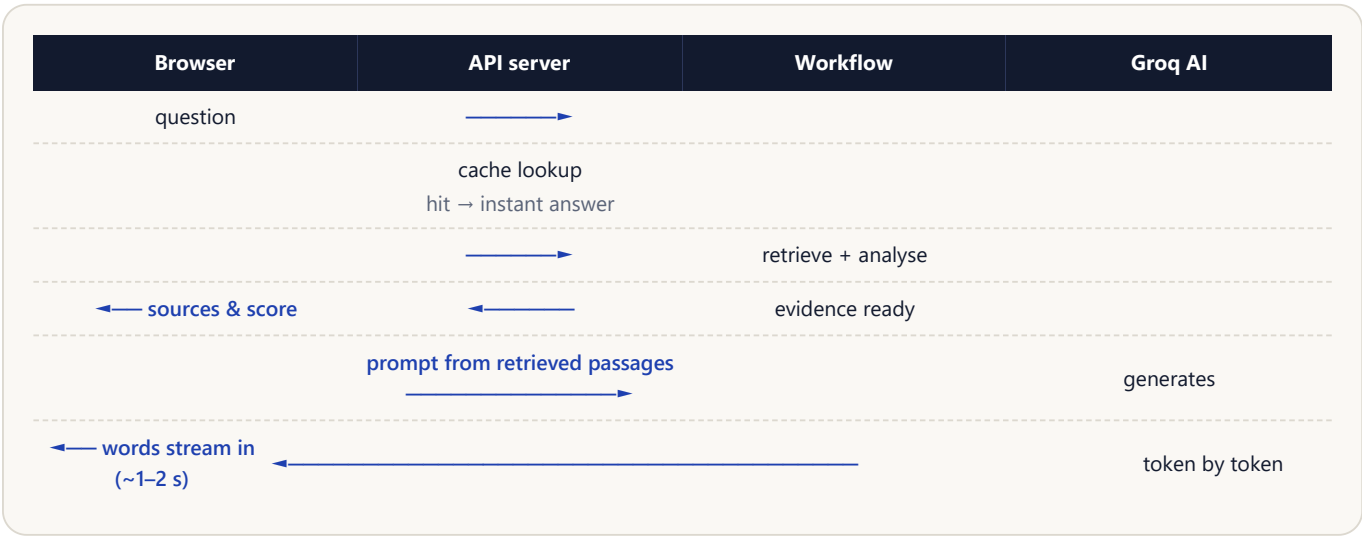



*Figure 4 — Server-Sent Events flow. Citations arrive before the first word; full answers finish in under 10 seconds.*

### Technology stack

| Layer | Technology |
|---|---|
| Frontend | React 18, TypeScript, Vite, Tailwind CSS, shadcn/Radix UI, Motion (animations), light & dark themes |
| Backend | Python, FastAPI, LangGraph (multi-agent workflow), Server-Sent Events streaming |
| AI model | Groq — `openai/gpt-oss-120b` primary, Qwen fallback, low reasoning effort for speed |
| Search | MiniLM embeddings, BM25Plus keyword index, legal knowledge graph, cross-encoder re-ranking |
| Storage | Qdrant / in-memory (vectors), Neo4j / in-memory (graph), SQLite (audits), LRU answer cache |
| Exports | PyMuPDF (PDF with Devanagari fonts), python-docx (Word), Markdown |

05 · COMPLIANCE ENGINE

## How a policy is checked against the Act

### The 11 obligations audited

| # | Obligation of a Data Fiduciary | DPDP section |
|---|---|---|
| 1 | Clear notice before collecting personal data | § 5 / § 6 |
| 2 | Free, specific, informed, unconditional consent | § 6(1) |
| 3 | Withdrawal of consent as easy as giving it | § 6(4) |
| 4 | Process only for disclosed lawful purposes | § 6(2) |
| 5 | Reasonable security safeguards, incl. encryption | § 8(5) |
| 6 | Notify Board and users of a personal-data breach | § 8(6) |
| 7 | Erase data on withdrawal or when purpose is served | § 8(7) |
| 8 | Appoint and publish a Data Protection Officer | § 8(9) |

| | | |
|---|---|---|
| 9 | Grievance redressal mechanism | § 8(10) / § 13 |
| 10 | Verifiable parental consent for children's data | § 9 |
| 11 | Honour rights of access, correction and erasure | § 11 – § 12 |

## Checking one obligation

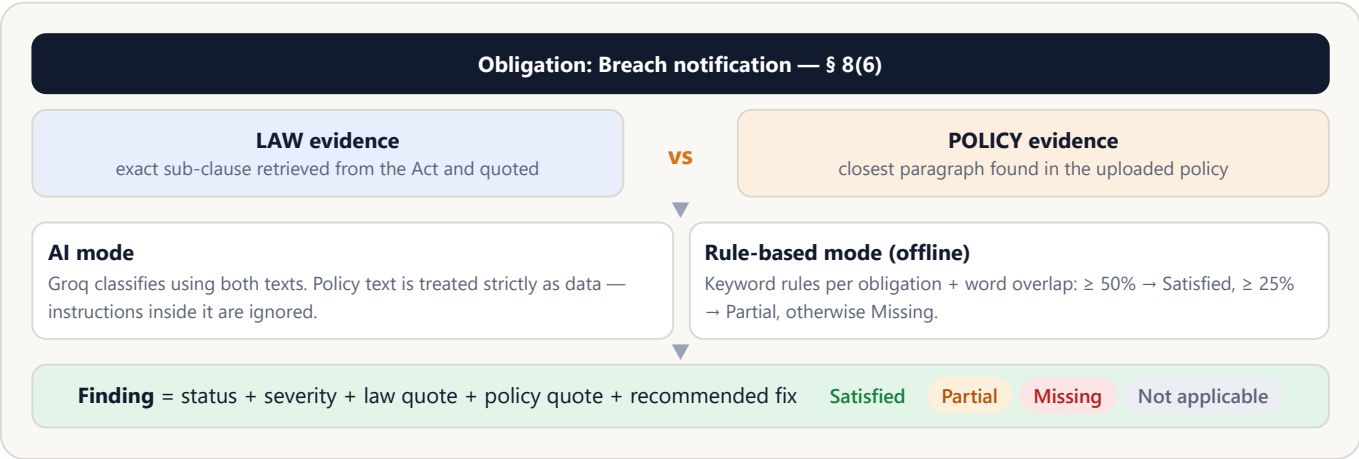



*Figure 5 — Per-obligation evaluation in compliance_agent.py.*

## Scoring

| Status | Weight | Meaning |
|---|---|---|
| Satisfied | 1.0 (full) | Policy clearly commits to the duty |
| Partial | 0.5 (half) | Mentioned but incomplete or vague |
| Missing | 0 | No matching commitment found |
| Not applicable | excluded | Duty doesn't apply — never counted against the company |

Score = (Satisfied + 0.5 × Partial) ÷ applicable obligations × 100 — deterministic and reproducible.

### The 7 guardrails (run before anything is shown)

| Check | What it prevents |
|---|---|
| Citation exists | Claims with no source |
| High-risk evidence | Serious findings resting on weak evidence |
| Hallucinated citation | Sections that don't exist in the Act |
| Confidence range | Implausible confidence values |
| Malformed output | Broken or incomplete AI responses |
| Prompt injection | Hidden instructions inside uploaded documents |
| Unsupported claim | Statements not backed by retrieved text |

### Outputs

- **Citizen:** short answer, what it means, relevant rights, cited sections, app trust score.
- **Business audit:** overall score, status per obligation, law vs policy side by side, recommended fixes.
- **Policy draft:** a complete privacy policy citing DPDP sections.
- **Downloads:** PDF (Hindi/Marathi supported), Word, Markdown.

06 · PROGRESS

# Development progress — 7 weeks

| Week | Milestone | Issue found → fixed |
|---|---|---|
| 1 | Planning, system design, ingestion of the Act | Chunker cut sections at 2,000 characters → full clauses preserved (71 passages) |
| 2 | Hybrid search engine | Keyword scoring gave zero weight on a small corpus → switched to BM25Plus; keyword search wasn't wired in → connected |
| 3 | AI agents, guardrails, scoring | Reports quoted the wrong section → each finding now quotes its exact sub-clause |
| 4 | Groq integration and streaming | Hidden SDK retries on rate limits caused delays → removed, fallback model added |
| 5 | Security hardening, 71 automated tests | Flaky internet-dependent test → runs offline; unknown apps got no answer → falls back to the Act |
| 6 | Frontend v1, 3-format downloads, persistent state | Cluttered UI with overflow → simplified; heavy PDF/Word tables → restyled |
| 7 | Final UI, animated landing page, documentation | Wasted space on wide screens → sidebar layout with side panels |

## Overall completion

| Area | Status | Progress |
|---|---|---|
| Knowledge base & search | Done |  |
| AI agents & compliance engine | Done |  |
| Guardrails & security | Done |  |
| Frontend & exports | Done |  |
| Evaluation benchmark | Partial |  |
| User accounts & deployment | Planned |  |

07 · STATUS

# Current status

| Capability | Status |
|---|---|
| Citizen Q&A — streaming, 3 languages | Working |
| Policy audit — 11 obligations | Working |
| Policy generation | Working |
| PDF / Word / Markdown export | Working |
| Guardrails & prompt-injection defence | Working |
| Automated tests | 71 / 71 pass |
| Speed — first words ~1–2 s, full answer < 10 s | Met |
| Light / dark themes, mobile layout | Working |
| User sign-in | Planned |

### Known limitations

- No user accounts yet — "Get started" opens the app directly.
- Groq free tier rate limits can slow answers under heavy load.
- In-memory indexes rebuild at each start (~20 s) when Qdrant/Neo4j aren't running.
- SQLite suits a single server; production needs Postgres.

08 · ROADMAP

# Next steps

| Phase | Focus | Deliverables |
|---|---|---|
| Oct 2026 | Foundations | User sign-in (email + OAuth); Postgres, Qdrant and Neo4j in Docker |
| Nov 2026 | Measurable quality | Full DPDP Rules 2025 ingestion; ~200-case benchmark in CI; dual-model agreement on high-risk findings |
| Dec 2026 | Product depth | Applicability engine; 72-hour breach-notice planner; consent-notice builder; team workspaces |
| Jan 2027 | Production | Monitoring and cost dashboards; cloud deployment; load test (p95 < 3 s to first token) |

**Why now:** every Data Fiduciary duty under the DPDP Act becomes enforceable in **May 2027**, with penalties up to **₹250 crore** per breach of security safeguards.